



SEGURANÇA DA **INFORMAÇÃO**



Prof. Dr. Felipe



Aula passada: Resumo

- **Informação:** É um ativo estratégico que precisa ser protegido.
- **Segurança da Informação:** Protege informações contra acessos, alterações, perdas e indisponibilidade.
- **Tríade CIA:** Confidencialidade, Integridade e Disponibilidade
- **Ameaças:** Podem causar danos às informações e aos sistemas.
- **Vulnerabilidades:** São fragilidades que podem ser exploradas.
- **Riscos:** Surgem quando ameaças podem explorar vulnerabilidades e gerar consequências.
- **Prevenção e Proteção:** Reduzem a probabilidade e os impactos dos incidentes.

Mas se uma organização possui vários riscos, quais devem ser tratados primeiro?

Objetivo

- Analisar riscos considerando **probabilidade e impacto**.
- Classificar e **priorizar riscos** para apoiar a tomada de decisão;
- Compreender como os riscos podem ser **tratados e reduzidos por controles de segurança**;
- Entender os princípios da **criptografia**, suas chaves e os modelos simétrico e assimétrico.

Identificar o risco é apenas o começo. É preciso avaliar, priorizar e definir como tratá-lo.

Nem todos os riscos são iguais

Uma empresa identificou diversas vulnerabilidades:

- Senhas fracas utilizadas por colaboradores;
- Sistema interno desatualizado;
- Dados de clientes armazenados sem proteção adequada;
- Ausência de backup de informações críticas;
- Computadores sem bloqueio automático;
- Funcionários suscetíveis a ataques de *phishing*.

Mas existe um problema: A empresa não possui recursos para corrigir tudo imediatamente.

Pergunta: Por onde começar? Todos esses riscos deveriam receber a mesma prioridade?

Resposta: Não. É necessário **avaliar os riscos** para determinar quais exigem maior atenção.

O que é Avaliação de Riscos?

É o processo de **identificar, analisar e comparar riscos** para determinar sua importância e apoiar a tomada de decisão.



Para cada risco, buscamos responder:

- Qual a chance de acontecer? **Probabilidade**
- Se acontecer, quais serão as consequências? **Impacto**
- A avaliação permite:

Comparar → Classificar → Priorizar → Tratar

A combinação entre probabilidade e impacto nos ajuda a estimar o nível do risco.

Probabilidade

A probabilidade representa a possibilidade de **um evento de risco ocorrer**, considerando as ameaças, vulnerabilidades e controles existentes.

- **Classificação:**

- ☐ **BAIXA: 1**

- Pouco provável de ocorrer nas condições atuais.

- ☐ **MÉDIA: 2**

- Pode ocorrer, pois existem condições que tornam o incidente possível.

- ☐ **ALTA: 3**

- Existe grande possibilidade de ocorrência ou evidências de que o incidente pode acontecer.

Para avaliar, podemos observar: Exposição à ameaça, Vulnerabilidades existentes, Histórico de incidentes, Controles implementados

Atenção: A existência de uma vulnerabilidade não significa que o incidente certamente acontecerá.

Probabilidade na prática

Cenário: Uma empresa possui **80 colaboradores** e utiliza e-mail diariamente para suas atividades. Nas últimas semanas:

- Foram recebidos diversos e-mails de *phishing*;
- Os colaboradores nunca receberam treinamento sobre *phishing*;
- Não existe procedimento específico para reportar mensagens suspeitas;
- Dois funcionários já clicaram em *links* suspeitos.

Pergunta: Qual é a probabilidade de ocorrer um incidente relacionado a *phishing*?
Baixa (1), Média (2) ou Alta (3)?

Resposta: ALTA (3). Existem exposição frequente à ameaça, vulnerabilidades humanas e histórico recente de comportamento de risco.

E se, a empresa implementar: Treinamento + filtro de e-mails + procedimento para mensagens suspeitas. A probabilidade permaneceria a mesma?

Resposta: Provavelmente não. Os controles implementados podem reduzir a probabilidade de ocorrência do incidente.

Impacto

O **impacto** representa a magnitude das consequências para a organização caso um incidente ocorra.

Classificação:

- ☐ **BAIXO (1):** Consequências pequenas, facilmente controladas e com pouco comprometimento das operações.
- ☐ **MÉDIO (2):** Consequências relevantes, podendo provocar prejuízos ou interrupções temporárias.
- ☐ **ALTO (3):** Consequências graves, podendo comprometer operações, informações, pessoas ou a própria organização.

O impacto pode envolver: Financeiro, Operacional, Legal, Reputacional, Estratégico, Humano

O impacto depende do contexto e do ativo afetado.

Impacto na prática

Mesmo incidente. Contextos diferentes.

Situação A (Loja de roupas): O sistema de vendas fica indisponível por **30 minutos**. Possíveis consequências:

- Algumas vendas são atrasadas;
- Atendimento temporariamente prejudicado;
- Operação é retomada rapidamente.

Situação B (Hospital): O sistema de prontuários fica indisponível por **30 minutos** durante atendimentos de emergência. Possíveis consequências:

- Profissionais ficam sem acesso ao histórico dos pacientes;
- Decisões clínicas podem ser atrasadas;
- O atendimento pode ser comprometido.

Pergunta: O tempo de indisponibilidade foi o mesmo. O impacto também é igual?

Resposta: Não. O impacto depende do contexto, da criticidade do ativo e das consequências provocadas pelo incidente.

Probabilidade vs. Impacto

Agora podemos combinar os dois elementos.

- Modelo simplificado de avaliação :

$$\text{Risco} = \text{Probabilidade} \times \text{Impacto}.$$

Neste modelo didático, utilizaremos uma escala de 1 a 3 para comparar os riscos.

- **Probabilidade:** Baixa = 1, Média = 2, Alta = 3.
- **Impacto:** Baixa = 1, Média = 2, Alta = 3.
- **Exemplo:** Um incidente possui:
 - **Probabilidade: Alta = 3** e **Impacto: Alto = 3.**
 - **Risco:** $3 \times 3 = 9$.

A pontuação ajuda a comparar e priorizar riscos.

Matriz de Risco

Transformando a avaliação em prioridade:

Impacto ↓ / Probabilidade →	Baixa (1)	Média (2)	Alta (3)
Baixo (1)	1	2	3
Médio (2)	2	4	6
Alto (3)	3	6	9

Classificação:

- 1-2 → Risco Baixo;
- 3-4 → Risco Médio;
- 6-9 → Risco Alto.

Quanto maior a pontuação, maior o nível de atenção indicado pela matriz.

Avaliando um risco

Cenário: Uma empresa armazena dados pessoais de milhares de clientes. Foi identificado que:

- O sistema está desatualizado;
- Existem vulnerabilidades conhecidas;
- O servidor pode ser acessado pela internet;
- Não há evidência de exploração até o momento;
- Um vazamento poderia expor milhares de clientes.

Avaliação

- Qual seria a **Probabilidade**?
- Qual seria o **Impacto**?

Resposta:

- **Probabilidade: Alta (3).** Existem vulnerabilidades conhecidas e exposição à internet.
- **Impacto: Alto (3).** Um incidente poderia comprometer dados de milhares de clientes.
- **Resultado: RISCO ALTO:** $3 \times 3 = 9$.

Maior impacto significa maior risco?

Compare dois cenários:

RISCO A: Falha em um sistema crítico.

- Probabilidade: **Baixa (1)** e Impacto: **Alto (3)**. **Risco:** $1 \times 3 = 3$.

RISCO B: Funcionários recebem constantemente tentativas de *phishing*.

- Probabilidade: **Alta (3)** e Impacto: **Médio (2)**. **Risco:** $3 \times 2 = 6$.

Pergunta: Qual apresenta maior nível de risco segundo nossa matriz?

Resposta: Risco B apresenta maior pontuação na matriz: 6 contra 3.

**Não devemos analisar somente o impacto ou somente a probabilidade.
O nível de risco resulta da combinação dos dois.**

Dois riscos com a mesma pontuação são iguais?

Compare:

- **Risco A: Vazamento de dados**

Probabilidade: **Alta (3)**, Impacto: **Médio (2)** e **Nível de risco = 6**

- **Risco B: Indisponibilidade de sistema crítico**

Probabilidade: **Média (2)**, Impacto: **Alto (3)** e **Nível de risco = 6**

Pergunta: Os dois receberam a mesma pontuação. Devem necessariamente receber a mesma prioridade?

Resposta: Não necessariamente.

A matriz ajuda a **classificar e comparar**, mas a decisão também deve considerar:

- Criticidade do ativo;
- Tipo de impacto;
- Obrigações legais;
- Pessoas afetadas;
- Controles existentes;
- Urgência;
- Recursos necessários para o tratamento.

A matriz apoia a decisão. Ela não substitui a análise do contexto.

Avaliar não é o mesmo que priorizar

Avaliação - Busca compreender o risco:

- Qual a probabilidade? Qual o impacto? Qual o nível de risco?

Priorização - Busca decidir a ordem de tratamento:

- Qual risco precisa de atenção primeiro?

Para priorizar, podemos considerar:

- **Nível do risco**
- **Criticidade do ativo**
- **Impacto para o negócio**
- **Exigências legais**
- **Urgência**
- **Custo e viabilidade do tratamento**

Dois riscos classificados como “altos” podem exigir decisões diferentes.

Qual você trataria primeiro?

A empresa possui recursos para tratar apenas **UM** risco neste mês.

- **Risco A - Banco de dados de clientes sem criptografia.**

Probabilidade: Média. Impacto: Alto. Risco: **6**. Tratamento estimado: R\$ 15.000.

Risco B - Funcionários suscetíveis a *phishing*.

Probabilidade: Alta. Impacto: Médio. Risco: **6**. Tratamento inicial: R\$ 3.000.

Pergunta: Qual deveria ser tratado primeiro? A ou B?

Resposta: Não existe uma resposta automática apenas pela pontuação.

Os dois possuem risco 6. A organização precisa analisar **contexto, consequências, custo, urgência e efetividade do tratamento.**

Sua decisão mudaria se o banco de dados armazenasse informações de saúde de 500 mil pessoas?

Identificamos e priorizamos o risco. E agora?

Até o momento: **Identificar → Avaliar → Classificar → Priorizar**

Agora precisamos responder: **O que fazer com o risco?**

Uma organização pode:

- **EVITAR:** Eliminar a atividade ou condição que gera o risco.
- **MITIGAR / REDUZIR:** Implementar controles para diminuir a probabilidade e/ou o impacto.
- **TRANSFERIR / COMPARTILHAR:** Transferir ou compartilhar parte das consequências com terceiros.
- **ACEITAR:** Reconhecer o risco e decidir mantê-lo dentro dos critérios estabelecidos pela organização.

Nem todo risco precisa ser eliminado, e nem todo risco pode ser eliminado.

Evitar x Mitigar

EVITAR: A organização elimina a atividade que origina o risco.

- **Exemplo:** Uma empresa permite acesso remoto a um sistema antigo que não pode ser atualizado com segurança.
- **Decisão:** desativar completamente o acesso remoto.
- **Resultado:** a exposição específica é eliminada.

MITIGAR / REDUZIR: A atividade continua, mas são implementados controles para reduzir o risco.

- **Exemplo:** A empresa precisa manter o acesso remoto.
- **Decisão:** implementar MFA, VPN, atualização do sistema e controle de acesso.
- **Resultado:** o acesso continua existindo, porém com menor exposição ao risco.

Pergunta: Qual das duas estratégias permite manter a atividade?

Resposta: Mitigar.

Transferir x Aceitar

TRANSFERIR / COMPARTILHAR: Parte das consequências do risco é atribuída ou compartilhada com outra organização.

- **Exemplo:** A empresa contrata um **seguro cibernético** para reduzir determinadas consequências financeiras de um incidente.
- **Atenção: Transferir não significa fazer o risco desaparecer.**
- A organização continua responsável por diversos impactos e obrigações.

ACEITAR: A organização reconhece o risco e decide não implementar novos controles naquele momento.

- **Exemplo:** Um sistema interno de baixa criticidade possui uma pequena vulnerabilidade.
- **Probabilidade: Baixa, Impacto: Baixo, Custo da correção: elevado**

A organização pode decidir **aceitar o risco**, desde que essa decisão seja consciente e compatível com seus critérios.

- **Pergunta: Aceitar um risco significa ignorá-lo?**
- **Resposta: Não.**

Aceitação é uma decisão consciente e documentada, não ausência de gestão.

Do risco ao controle

Já sabemos: **Identificar → Avaliar → Classificar → Priorizar → Tratar**

Mas, quando decidimos **mitigar** um risco, surge uma nova pergunta: **Qual controle devemos implementar?**

- Um controle de segurança é uma medida implementada para modificar o risco, reduzindo sua probabilidade e/ou suas consequências.

Exemplos

- **Risco:** acesso não autorizado → Controle de acesso + MFA
- **Risco:** perda de dados → *Backup*
- **Risco:** *phishing* → Filtro de e-mail + treinamento
- **Risco:** exposição de dados confidenciais → Criptografia + controle de acesso

O controle deve ser escolhido de acordo com o risco identificado.

Um controle pode reduzir o quê?

Quando implementamos um controle, ele pode atuar sobre:

- **PROBABILIDADE:** Reduzindo a chance de o incidente acontecer.
- **Exemplo:** Treinamento contra *phishing* reduz a probabilidade de um colaborador clicar em um link malicioso.
- **IMPACTO:** Reduzindo as consequências caso o incidente aconteça.
- **Exemplo:** *Backup* não impede uma falha de disco, mas pode reduzir o impacto da perda dos dados.
- **OU AMBOS:** Alguns controles podem contribuir para reduzir diferentes componentes do risco.
- **Pergunta:** Todo controle impede que o incidente aconteça?
- **Resposta:** Não.

Alguns controles reduzem a **probabilidade**, outros reduzem o **impacto** e alguns atuam sobre ambos.

Risco antes x Risco depois do controle

Situação inicial: Funcionários recebem frequentemente e-mails de phishing.

• **Probabilidade: Alta (3), Impacto: Alto (3), $3 \times 3 = 9$, Risco inicial: ALTO**

- **Controles implementados**

- Treinamento periódico;
- Filtro de e-mails;
- Autenticação em dois fatores;
- Procedimento para reportar mensagens suspeitas.

Nova avaliação: Probabilidade: Média (2), Impacto: Alto (3), $2 \times 3 = 6$. O risco diminuiu, mas não desapareceu.

Os controles reduziram a probabilidade estimada, mas um incidente bem-sucedido ainda poderia produzir consequências graves.

Risco Residual

No exemplo anterior:

- **Antes dos controles.** Risco = 9 → Controles de segurança → Depois dos controles. Risco = 6.
- **O risco que permanece após a implementação dos controles é chamado de: RISCO RESIDUAL.**

Definição: Risco residual é o risco que permanece após a implementação das medidas de tratamento e dos controles de segurança.

Pergunta: É possível eliminar completamente todos os riscos?

Resposta: Geralmente, não.

O objetivo da gestão de riscos é mantê-los em **níveis aceitáveis para a organização.**

Exemplo Geral

- **Cenário:** Uma empresa mantém informações de clientes em um servidor antigo e desatualizado, acessível pela internet.

A organização identificou:

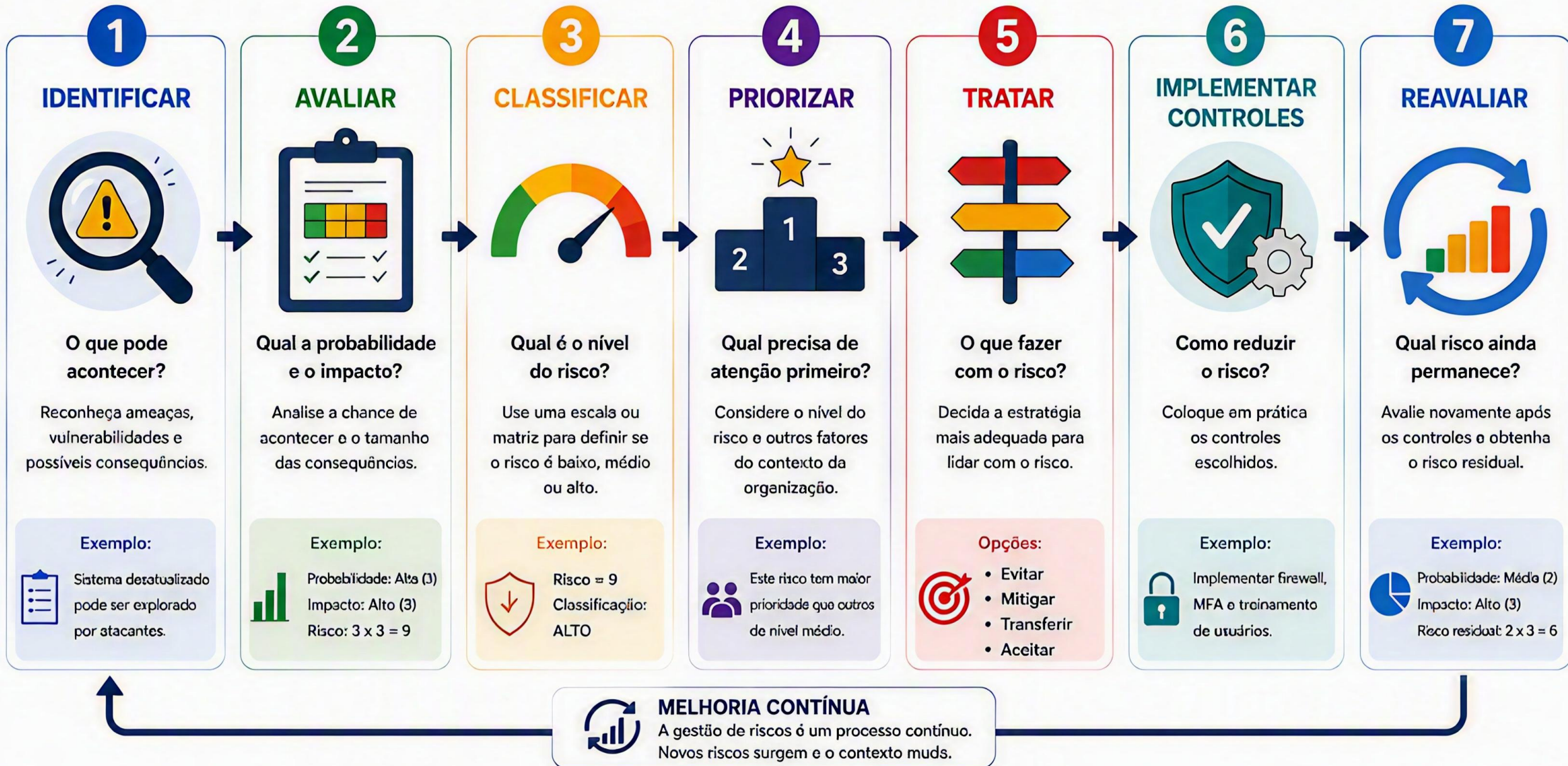
- **Ameaça:** Ataque cibernético.
- **Vulnerabilidade:** Sistema desatualizado.
- **Possível consequência:** Vazamento de dados de clientes.
- **Avaliação: Probabilidade:** Alta (3), **Impacto:** Alto (3), Risco = 9. **RISCO ALTO**

Decisão: A empresa precisa continuar utilizando o sistema temporariamente.

- **Evitar?** Não é viável neste momento.
- **Mitigar?** Sim.
- **Possíveis controles:** Atualização/migração do sistema + restrição de acesso + monitoramento.

Depois dos controles, o risco deve ser avaliado novamente.

GESTÃO DE RISCOS EM 7 PASSOS



ATIVIDADE



OBRIGADO!

Até a próxima aula!

